

D A Y 03

Cloud Security

Digital Science Program

Cloud Computing & Big Data Analytics

Prepared by Cyber.SoHo | Graduate Level

Today's Agenda

Lesson 1: Cloud Security

- 01** What Is Cloud Security & Why It Matters
- 02** The CIA Triad (Confidentiality, Integrity, Availability)
- 03** IAM — Identity and Access Management
- 04** Encryption — At Rest and In Transit
- 05** Network Security — VPCs, Firewalls, Zero Trust
- 06** Monitoring, Logging & Incident Response
- 07** Compliance Frameworks & Certifications
- 08** Emerging Threats & The Future

01 Why Should Data Scientists Care?

Spinning up a Jupyter notebook on AWS makes you a link in the security chain

A single misconfigured S3 bucket has exposed millions of medical records

A leaked API key can cost thousands in hijacked compute charges

Security is not optional — it is woven into every stage of the data lifecycle

01 What Is Cloud Security?

The collection of policies, technologies, controls, and practices designed to protect cloud-based systems, data, and infrastructure.

Three Unique Challenges:

Scale & Elasticity

Vulnerabilities replicate as fast as auto-scaling spins up new instances

Multi-Tenancy

Your VM shares physical hardware with other tenants — isolation is software-enforced

Shared Responsibility

Provider secures the cloud; you secure what's in it

01 The Shared Responsibility Model

Provider — "Security OF the Cloud"

- Physical data centre security
- Hypervisor & host OS patching
- Network infrastructure
- Hardware decommissioning
- Managed service internals
- Global infrastructure

Customer — "Security IN the Cloud"

- IAM policies & access controls
- OS patching on EC2 instances
- Security Group & NACL rules
- Data encryption & key management
- Application-level security
- Data classification & compliance

01 Responsibility Shifts by Service Type

IaaS

(Infrastructure as a Service)

Customer manages almost everything above the hypervisor

PaaS

(Platform as a Service)

Shared — provider handles OS; customer handles app & data

SaaS

(Software as a Service)

Provider manages nearly everything; customer owns data & access

Key Insight: The higher up the stack, the less you manage — but you always own your data and access controls.

01 The Flat Analogy

Building Management = Cloud Provider

- Structural integrity
- Main entrance lock
- Fire escapes
- Water supply

You, the Tenant = Customer

- Lock your own front door
- Close windows at night
- No hazardous storage
- Your guests, your liability

Burglar enters via main gate → Provider's fault | Burglar enters via your open window → Your fault

KEY TAKEAWAY

The #1 cause of cloud breaches is misunderstanding where the provider's responsibility ends and yours begins. Always know which side of the line you are on.

02 The CIA Triad — Three Pillars of Security

C

Confidentiality

Data accessible only to authorised parties

I

Integrity

Data has not been tampered with

A

Availability

Systems and data accessible when needed

All three must hold simultaneously. Sacrificing one creates unacceptable risk.

02 CIA — Confidentiality

"Who can see the data?"

Cloud Controls:

- AES (Advanced Encryption Standard)-256 encryption at rest
- TLS (Transport Layer Security) 1.3 in transit
- IAM policies & MFA (Multi-Factor Authentication)
- VPC (Virtual Private Cloud) isolation
- KMS (Key Management Service) for key management
- Data classification tags

Breach Example

An unauthorised nurse accesses a celebrity's medical records — a violation of patient confidentiality.

02 CIA — Integrity

"Has the data been altered?"

Cloud Controls:

- SHA-256 checksums & hash digests
- S3 versioning & immutable backups
- CloudTrail logging & audit trails
- Database constraints & input validation
- Code signing

Breach Example

An attacker changes a patient's blood type in the database — a data poisoning attack that could be fatal.

02 CIA — Availability

"Can we access the data when needed?"

Cloud Controls:

- Multi-AZ (Availability Zone) deployment
- Auto-scaling groups
- CDN (Content Delivery Network) distribution
- DDoS (Distributed Denial of Service) protection
- Health checks, failover & disaster recovery
- SLA (Service Level Agreement) monitoring

Breach Example

Ransomware locks doctors out of patient records during an emergency — availability failure with life-threatening consequences.

02 CIA Triad in a Data Pipeline

Pipeline Stage	CIA Pillar	Key Control
Data Ingestion	Confidentiality	TLS 1.2+, input validation
Processing (ETL)	Integrity	Checksums, hash digests, logging
Storage (Warehouse)	Availability	Multi-AZ replication, backups

KEY TAKEAWAY

Every security decision should be evaluated through the CIA lens. Ask:
Does this protect confidentiality? Does it ensure integrity? Does it
maintain availability?

03 IAM — The Gatekeeper

Authentication

"Who are you?"

- Passwords & API keys
- OAuth (Open Authorization) tokens
- Certificates & MFA

Authorisation

"What can you do?"

- IAM policies & role definitions
- Resource-level permissions
- Condition-based access

Key Concepts

- PoLP (Principle of Least Privilege) — minimum permissions, nothing more
- RBAC (Role-Based Access Control) — permissions tied to roles, not individuals
- NIST SP 800-53 (AC-6) — codifies least privilege as a foundational control
- ABAC (Attribute-Based Access Control) — conditions like time, location, device

03 Principle of Least Privilege in Practice

Good — Junior Data Scientist

- s3:GetObject on one specific bucket
- sagemaker:CreatePresignedNotebookUrl on one notebook
- logs:GetLogEvents on one log group
- Start with zero, add only what's needed

Bad — The "Admin" Shortcut

- s3:* (all actions on all buckets)
- ec2:TerminateInstances (destroy resources)
- iam:CreateUser (privilege escalation risk)
- "Just use the admin account for now"

03 Case Study — Capital One (2019)

106 MILLION

customer records exposed

- Root cause: Overly permissive IAM role on a WAF (Web Application Firewall) config
- Attack path: Attacker called EC2 metadata service → retrieved temp credentials → accessed S3
- Data included: Names, addresses, credit scores, Social Security numbers
- Lesson: A single misconfigured role can compromise an entire AWS account

KEY TAKEAWAY

Start with zero permissions and add only what is needed. Overly broad IAM policies are behind the majority of cloud breaches. When in doubt, deny.

04 Encryption — Two States of Protection

Encryption at Rest

Protects data stored on disk

- Databases, object stores, backups
- AES-256 standard algorithm
- SSE-S3 / SSE-KMS / SSE-C models
- Azure Storage Service Encryption
- GCP default encryption + CMEK

Encryption in Transit

Protects data moving between systems

- TLS (Transport Layer Security) 1.2 / 1.3
- The padlock icon in your browser
- Google ALTS for inter-DC traffic
- OWASP: AES-256 symmetric
- OWASP: RSA $\geq$ 2048-bit asymmetric

Rule: Never store encryption keys alongside the data they protect.

04 Key Management Models

Model	Who Manages Keys?	Example
SSE with provider keys	Provider	SSE-S3
SSE with KMS	Customer (via managed service)	SSE-KMS, Azure Key Vault
SSE with customer keys	Customer (fully)	SSE-C, CMEK
Client-side encryption	Customer (before upload)	AES-256 + PBKDF2

HSMs (Hardware Security Modules)

Tamper-resistant physical devices for key material. FIPS 140-2 Level 3 validated. Available as: AWS CloudHSM, Azure Dedicated HSM, Google Cloud HSM.

KEY TAKEAWAY

Encryption is not a checkbox — it is a practice. Client-side encryption adds a second lock. Even if the bucket is misconfigured, attackers see only ciphertext without your key.

05 Network Security — VPCs

Your private floor in a massive office building

VPC

Virtual Private Cloud — logically isolated network section you control

Subnets

Public (internet-facing) and Private (internal only) subdivisions

Route Tables

Define traffic paths between subnets and gateways

IGW

Internet Gateway — entry point for public traffic

NAT Gateway

Allows private resources outbound-only internet access

05 Security Groups vs. NACLs

Feature	Security Groups	NACLs
Level	Instance	Subnet
Statefulness	Stateful (return traffic auto-allowed)	Stateless (define both directions)
Default	Deny all inbound; allow all outbound	Allow all
Rule type	Whitelist only (Allow)	Allow and Deny rules
Granularity	Fine-grained	Coarse-grained

05 Zero Trust Architecture

"Never Trust, Always Verify"

1

Verify Continuously

Authenticate at every request, not just at login

2

Least Privilege

Grant minimum access dynamically, contextually

3

Assume Breach

Segment and contain — treat every zone as hostile

Standards: NIST SP 800-207 | Implementation: Google BeyondCorp

05 Secure VPC – Two-Tier Design

Public Subnet (10.0.1.0/24)

NAT Gateway

Bastion Host

Load Balancer

Private Subnet (10.0.2.0/24)

ML Training Cluster

Database (RDS)

App Servers

Rule: Training instances must never be directly reachable from the internet.

KEY TAKEAWAY

Defence in depth means multiple layers — VPCs, Security Groups, NACLs, and Zero Trust. A misconfigured security group (e.g., SSH open to 0.0.0.0/0) is a leading breach vector.

06 Monitoring & Logging

Cloud-Native Logging Services

AWS CloudTrail

Logs every API call (who, what, when, where)

Azure Monitor

Activity Log — Microsoft ecosystem equivalent

Google Cloud Audit Logs

Part of Cloud Logging — admin & data access events

SIEM (Security Information and Event Management)

- Aggregates logs from multiple sources
- Applies correlation rules and generates alerts
- Examples: AWS Security Hub, Microsoft Sentinel, Google Chronicle, Splunk

06 Incident Response — NIST SP 800-61r2

1

Preparation

Policies, tools, trained response team

2

Detection & Analysis

Alerts, log analysis, user reports

3

Containment & Recovery

Stop the bleeding, remove threats, restore

4

Post-Incident Activity

Lessons learned, defence updates

KEY TAKEAWAY

Prevention is essential, but no system is impervious. The speed and quality of your incident response depends entirely on the logging data you have been collecting. Log everything, review regularly.

07 Compliance Frameworks (1/2)

GDPR

(General Data Protection Regulation)

Scope:

EU personal data

Requirement:

Consent, right to erasure, DPIA

Penalty: 4% revenue or €20M

HIPAA

(Health Insurance Portability Act)

Scope:

US health data (PHI)

Requirement:

Encryption, audit logs, BAA

Penalty: Up to \$1.9M/violation

PCI DSS

(Payment Card Industry Data Security Standard)

Scope:

Cardholder data

Requirement:

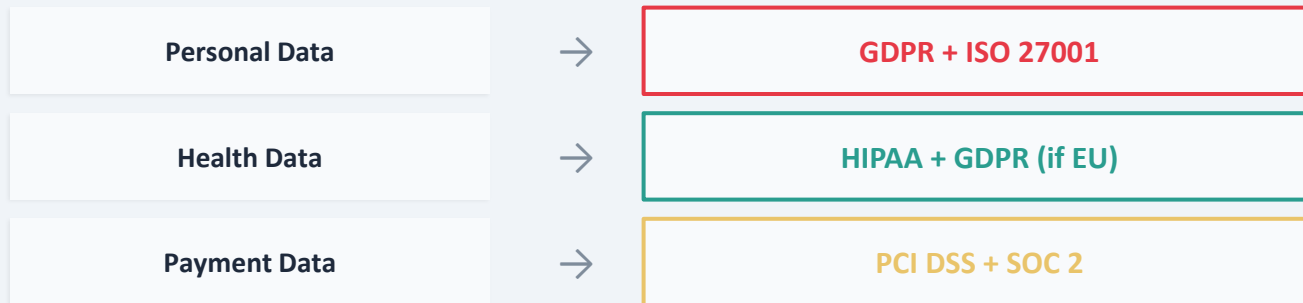
Network segmentation, scans

Penalty: Fines + loss of processing

07 Compliance Frameworks (2/2)

Framework	Scope	Key Requirement
ISO/IEC 27001	Global info security	ISMS, annual risk assessments
SOC 2	Service providers	Security, availability, integrity, confidentiality, privacy
NIST SP 800-53	US federal systems	Comprehensive security & privacy controls catalogue

Compliance Decision Tree



KEY TAKEAWAY

Compliance is not optional. The type of data you handle determines which frameworks apply. Map data categories to regulations before writing a single line of pipeline code.

08 Emerging Threats — Supply Chain Attacks

- Target: Software dependencies your cloud apps rely on
- SolarWinds (2020): Compromised one tool → accessed thousands of organisations
- Data Science Risk: Compromised PyPI package injects malicious code into ML pipelines
- Typo-squatting: Packages named 'numpY' or 'pandass' execute arbitrary code

Defences:

- Dependency scanning (pip-audit, safety, Snyk)
- Lock files with hash verification (requirements.txt with hashes)
- Pin specific versions — never use unversioned installs in production
- Reference: NVD (National Vulnerability Database) at nvd.nist.gov

08 Containers, Serverless & AI Threats

Container Security

- Shared host OS kernel — escape risk
- Follow CNCF best practices
- Scan images before deployment

Serverless Security

- Ephemeral — harder to monitor
- Function-level IAM critical
- Input validation essential

AI-Powered Arms Race

Attackers

- Automated phishing
- Faster vulnerability discovery
- Detection evasion

Defenders

- Anomaly detection in SIEM
- Behavioural analytics
- Automated response (SOAR)

KEY TAKEAWAY

The threat landscape evolves constantly. Supply chain attacks target the exact packages you install daily. Scan dependencies, use lock files, and stay current with MITRE ATT&CK.

Course Summary

Topic	Core Concept
Shared Responsibility	Provider secures the cloud; you secure what's in it
CIA Triad	Confidentiality, Integrity, Availability — the security lens
IAM & Least Privilege	Start with zero permissions, add only what's needed
Encryption	Encrypt at rest and in transit; manage keys separately
Network Security	VPCs + Security Groups + Zero Trust = defence in depth
Monitoring & IR	Log everything; follow NIST's 4-phase IR framework
Compliance	Data type determines applicable regulations
Emerging Threats	Supply chain, containers, AI arms race

THE GOLDEN RULE

Security Is Not a Feature It Is a Practice

Security must be woven into every stage of your data science workflow — from pip install to model deployment to data archival.

Essential Resources (1/2)

Cloud Security Alliance

cloudsecurityalliance.org

AWS Shared Responsibility

aws.amazon.com/compliance/shared-responsibility-model

NIST Cybersecurity

nist.gov

OWASP

owasp.org

MITRE ATT&CK Cloud

attack.mitre.org/matrices/enterprise/cloud

NVD

nvd.nist.gov

Essential Resources (2/2)

AWS CloudTrail

docs.aws.amazon.com/cloudtrail

Azure Monitor

learn.microsoft.com/azure/azure-monitor

Google Cloud Logging

cloud.google.com/logging/docs

CIS Benchmarks

cisecurity.org/cis-benchmarks

SANS Cloud Security

sans.org/cloud-security

Google BeyondCorp

cloud.google.com/beyondcorp

Disclaimer (1/2)

- This material is the intellectual property of Cyber.SoHo. All rights reserved.
- Cyber.SoHo has no affiliation, partnership, or endorsement with any company, organisation, or product mentioned herein.
- All trademarks are property of their respective owners. Mention does not constitute endorsement.
- Users are advised to verify all external links using tools such as VirusTotal ([virustotal.com/gui/home/url](https://www.virustotal.com/gui/home/url)).

Disclaimer (2/2)

- Material provided "as is" without warranty. Cyber.SoHo is not liable for damages arising from use.
- Code examples are for educational purposes only — not intended for production without review.
- Security techniques discussed are for defensive and authorised testing only.
- Unauthorised use of information for exploitation or illegal activity is strictly prohibited.

Thank You

Day 03: Cloud Security — Complete

Prepared by Cyber.SoHo | All Rights Reserved